



**ВТУ “Св. Св. Кирил и Методий”
Факултет “Математика и информатика”**

Реферат

Електронен подпис

Изготвил:

Николета Панайотова

Фак. №: МПИ-10679р

Увод

Цифровият подпис осигурява удостоверяване на автентичността на източника на съобщението, неговата цялост и юридическа значимост (цифровият подпис е еквивалентен на собственоръчния подпис). В Република България се използват три типа електронен подпис, както следва:

- ☉ **Обикновен е-подпис.** Не се изискват средства за идентификация титуляра като сертификат (удостоверение). Достатъчно е двете страни (автор на е-подписа и адресат) да са се договорили предварително за способа, по който ще се идентифицират и ще автентифицират своите изявления. Целта е в частно-правните и вътрешнокорпоративните отношения на двете страни да се използва технология, която е по-евтина и достатъчно сигурна. Обикновеният е-подпис се приравнява със саморъчния подпис.
- ☉ **Усъвършенствуван е-подпис.** Предполага използването на асиметрична криптограма. Може да се прилага само когато за него име издаден сертификат от доставчик на удостоверителна услуга (ДУУ). По аналогия с първата разновидност, и усъвършенствуваният е-подпис е подходящ за частно-правните отношения, когато двете страни се познават и комуникират по интернет.
- ☉ **Универсален е-подпис.** Вариант на усъвършенствувания е-подпис. Трябва да отговаря на много високи изисквания. Може да се използва както в частно-правните, така и в публично-правните отношения. Освен собственика на електронния подпис и адресата, тук е необходима и трета доверена страна - доставчик на удостоверителни услуги (ДУУ), който проверява съществуването на дадено лице и гарантира истинността на информацията, с която то се идентифицира.

В настоящия реферат ще бъдат разгледани усъвършенствания и универсалния е-подписи.

1. Същност

Електронният подпис се състои от два уникални ключа от букви и цифри с определена дължина и информация за собственика. Единият ключ е така нареченият частен ключ (*Private Key*), който се пази единствено при собственика на подписа и не трябва да бъде споделян с никого. Другият ключ е публичен (*Public Key*) и е достъпен за всички. Публичните ключове се съхраняват във файлове наречени “пръстен от ключове”. В интернет има няколко сървъра с такива публични ключове, като те не автентифицират ключовете, а просто ги съхраняват. Освен това, ключовете и сертификатите имат период на валидност. Списъците с валидните и невалидни регистрации също са публикувани и е желателно да бъдат проверени преди осъществяване на взаимоотношения с лицето или фирмата.

Изпращачът кодира съобщението със своя частен ключ. Получателят използва публичния ключ, за да декодира съобщението. Важно е да се отбележи, че декодирането може да стане единствено с публичния ключ. Двойката частен и публичен ключ работят единствено един с друг и именно това гарантира, че от изпращането до пристигането на електронния документ никой не го е променял.

Всеки може да декриптира хеш кода на съобщението, тъй като публичния ключ може да се намери в директорията за публични ключове на сървъра. Само че фактът, че е декриптиран хеш на съобщението с публичния ключ на определен човек доказва само, че това съобщение идва точно от този човек. Само този, който притежава персоналния ключ може да създаде съобщение, което може да се декриптира със съответния публичен ключ.

Това е основната концепция при асиметричните криптосистеми – ключът за криптиране (частният) е различен от ключа за декриптиране (публичния). Това се постига чрез сложни математически изчисления. Те осигуряват високата степен на надеждност на асиметричните криптосистеми. Единственият проблем е да се намери ефективен начин да се разменят ключовете.

За разлика от тях, по-широко разпространени са симетричните криптосистеми, при които с един и същ ключ се криптира и декриптира. Но те са много по-бързи, а това е много важно за потребителите на *Internet*. Заради бързината, криптирането с публичен ключ не е препоръчително да се използва за големи файлове. За да може една система да бъде и защитена и бърза, е необходимо да се комбинират и двата типа криптография. Затова в електронните подписи и *e-mail* криптирането се използват хибридни криптосистеми, съчетавайки сигурността на асиметричните, с бързината на симетричните криптосистеми.

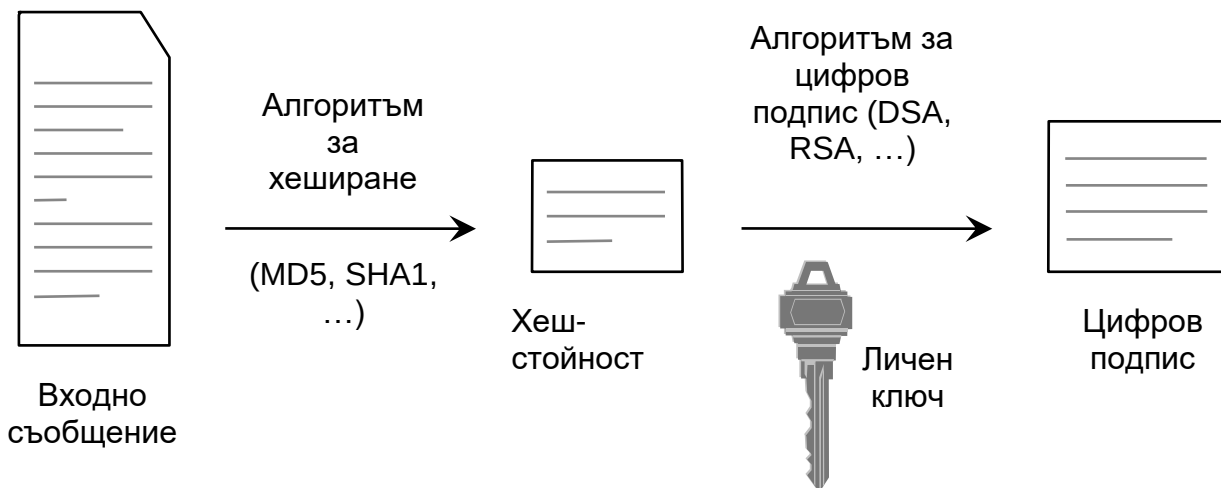
Най-популярната хибридна система за криптиране на информацията при работа в интернет е *PGP*. В миналото използването на *PGP* е било забранено за експорт от САЩ. Последните версии на *PGP* обаче използват отворени ключове *RSA*. Други алгоритми, с които се работи са *AES*, *DES*, *3DES* и други. Работи се много големи числа като 310-цифрените десетични числа са границата, за която се смята, че вече не е много сигурна. Затова се преминава към 620 или дори 1240-цифрени числа. Алгоритъмът *RSA* се свежда до факторизация (разлагане на много голямо число на простите му множители. В общия случай, известните рекорди при факторизация на големи числа са свързани с *RSA challenge* - състезания организирани от *RSA security* и печелени от германски университети. Това подтиква преминаване към 2048-битови *RSA* ключове и нагоре.

2. Алгоритъм

*** На първа стъпка съобщението се хешира.**

Като начало е необходимо само една малка част от съобщението да се криптира с персонален ключ. Тази част се нарича *Digital Hash*. Хеш кодът е функция, която намалява всяко едно съобщение до фиксиран брой битове. Той може да се разглежда като печат върху плик. Изпращането на този код заедно с електронна поща ще гарантира, че никой не може да промени съдържанието на пощата по време на

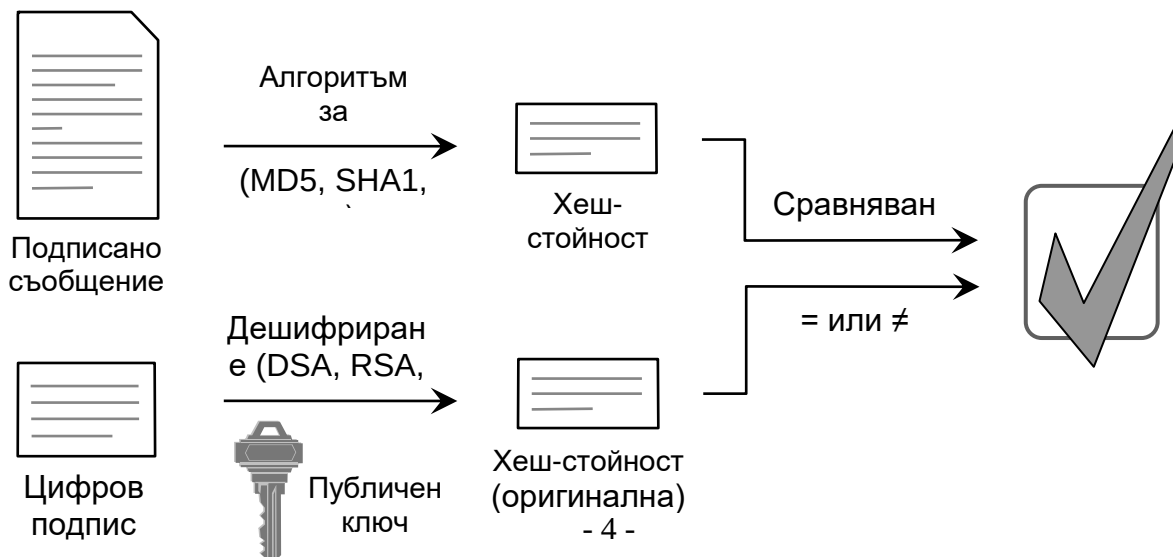
предаване, но това не носи сигурност за изпращача. Тъй като кодирането и хеширането предлагат сигурност на различни нива, честа практика сред *web* разработчиците е да реализират както кодиране, така и хеширане, за да се постигне по-висока степен на сигурност.



* **На втората стъпка** цялото съобщение се криптира с частния ключ на изпращача. За целта се използва математически алгоритъм за цифров подпис (*Digital Signature Algorithm*), който преобразува хеш-стойността в шифрирана хеш-стойност, наричана още цифров подпис. Най-често се използва *RSA* (основан на теорията на числата), *DSA* (теорията на дискретните логаритми) и *ECDSA* (теорията на елиптичните криви). Полученият цифров подпис често пъти се прикрепя към края на съобщението в специален формат, за да може да бъде верифициран на по-късен етап, когато това е необходимо.

При цифровите подписи, хеш се използва, за да се докаже идентичността на автора, цялостността на съобщението (интегритет) и да се спести време (криптирането на цяло съобщение само за целите на подписа отнема много време).

* **На трета стъпка** се дешифрира цифровият подпис, който трябва да бъде проверен със същия алгоритъм, който е използван при шифрирането. Дешифрирането става с публичния ключ, съответстващ на частния ключ, който е използван при подписването на съобщението. В резултат трябва да се получи оригиналната хеш-стойност, която е била получена при хеширането на оригиналното съобщение в първата стъпка от процеса на подписването му.



* **На четвърта стъпка** се сравняват текущата хеш стойност, получена от първата стъпка и оригиналната хеш стойност, получена от трета стъпка. Ако двете стойности съвпадат, верифицирането е успешно и доказва, че документът е бил подписан именно с личния частен ключ, съответстващ на публичния ключ, с който се извършва верификацията. Ако двете стойности се различават, това означава, че цифровият подпис е невалиден, т.е. или е повреден, или документът е преправен, или съответства на друго лице. Съответствието между публичен ключ и конкретно лице се установява чрез цифров сертификат (*Public Key Certificate*), издаден от *Certificate authority (CA)*.

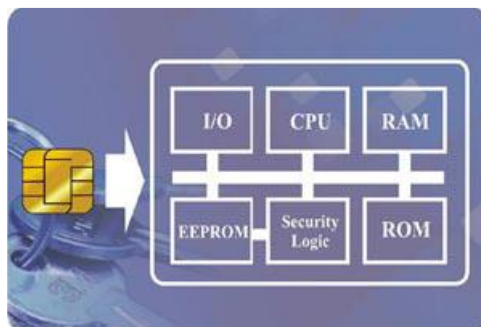
3. *E-mail* кореспонденция

Електронните подписи се използват и при кореспонденции по *e-mail*. Някои от използваните технологии за целта са:

- ☒ **PGP (*Pretty Good Privacy*)** е много сигурна, софтуерно реализирана криптографска система за защита на предаваните по ел. поща съобщения и на съхраняваните данни, създадена първоначално от Филип Цимерман в *MIT*. *PGP* използва хибридните криптографски схеми и цифрово подписване, за да се засекрети текста на изпратеното съобщение и той да бъде цифрово подписан. *PGP* обикновено използва *RSA* криптиране с публичен ключ за размяна на ключове и *IDEA* за криптиране на съобщения. През последните години *PGP* се наложи като стандарт за сигурна ел.поща в *INET* и за шифриране на съхранявани върху носители файлове.
- ☒ **TLS (*Transport Layer Security*)** - криптира сегментите на транспортния слой при мрежовата комуникация, използвайки асиметрична криптография при обмена на ключове, симетрично криптиране за постигане на поверителност и персонален код за удостоверяване на съобщението. Предотвратява подслушването и фалшифицирането като предлага идентификация и поверителност на комуникациите в интернет чрез използване на *RSA* с 1024 и 2048-bit дължина.
- ☒ **S/MIME (*Secure/Multipurpose Internet Mail Extensions*)** е защитно разширение на стандарта за електронна поща *MIME*, базирано на технология на *RSA Data Security* с протоколи за криптографска защита и *Secure Hash Algorithm (SHA)*. Той се поддържа от *Netscape Communicator* и *Internet Explorer*, което го прави доста по-лесен за настройка. За използването на *S/MIME* не се изисква никакъв допълнителен софтуер, а само цифров сертификат, който може да се получи от много места, като *TrustCenter* (www.trustcenter.de) или *GTE* (www.gte.com).

4. Смарт карти и електронни транзакции

Устройството, на което се съхраняват електронните подписи е под формата на флашка или смарт карта. Препоръчително е използването на смарт карта, т.к. нейният чип съдържа крипто-контролер, който играе ролята на хардуерен ускорител и засилва бързодействието на процесите.



Съществуват разнообразни решения на проблема за шифрирането на *web*, но повечето от тях все още не са достатъчно добре оформени и обособени като стандарти. Само протоколите *Secure HTTP (S-HTTP)* и *Secure Sockets Layer (SSL)* са приети като стандарти и се прилагат за защита в интернет.

Secure Electronic Transactions (SET) - защитени електронни транзакции. За защита на плащанията с кредитни карти са създадени два стандарта - *SSL* и *SET*, създаден от *Visa* и *MasterCard*. Разликите между *SSL* и *SET* са значителни - *SSL* кодира само трафика между браузъра и сървъра (компютрите на потребителя и търговеца), докато *SET* представлява напълно завършено решение за разплащане, включващо не само купувача и търговеца, но и банките.

5. Атаки и пробиви в сигурността

Въпреки високата степен на сигурност, която предоставят, алгоритмите с които работят електронните подписи са подложени на непрестанни атаки. Целта са големите възможности за парични транзакции. Само преди година са осъществени два големи пробива, известни като:

Spear phishing

През 2011 г. *Spear phishing* имейл е бил изпратен до две малки групи в компанията на *RSA*, поделението за сигурност на *EMC*. Въпреки че имейлът е бил автоматично отбелязан като спам, заглавието на съобщението „План за назначения 2011” изкушил един от служителите да отвори прикачения *Excel* файл. Файлът съдържа вграден флаш филм, който използвал уязвимост на *Flash* (впоследствие *Adobe* пуснали *patch* за уязвимостта). От флаша се инсталирала модифицирана версия на [Poison Ivy](#) – инструмент за отдалечен контрол (*Remote Administration Tool*), осигуряващ отдалечен достъп до файлове, регистри, следене на мрежовия достъп, стартиране и спиране на програми, т.е. всичко, което служителят може да прави локално. Чрез *Poison Ivy* са откраднати потребителски правомощия и впоследствие достъп за извличане на поверителна информация. Компанията обяви, че е станала жертва на „изключително сложна” атака. В действителност тя е отнела не повече от 10 минути, както демонстрира Шон Ханна на 18 май, по време на [Отворения ден на етичното хакерство](#), организиран съвместно от *New Horizons Bulgaria* и *EC-Council*. Шон Ханна е бил в България като лектор на [първите за страната курсове](#) за Етични хакери (*CEHv7*) и Следователи на цифрови престъпления (*CHFI*).

Атака над *Secure ID*

По-късно през 2011 г. президентът на *RSA Tom Heiser* обявява, че е осъществен *APT – Advanced Persistent Threat*. С придобитата информация се неутрализират *SecurID* продуктите на фирмата. *SecurID* изисква при влизане в дадена система, освен паролата, да се въведе и номер, който се сменя на всеки 30 секунди. Технологията се използва от фирми, разработващи строго секретни продукти, предназначени за отбраната.

6. Заключение

Ролята на електронните подписи в юридическата теория и практика ще нараства поради все по-широкото им навлизане във всички дейности, свързани с документацията в администрацията, отношенията между икономическите субекти, физическите и юридическите лица, електронното правителство и електронното гласуване и др.

Важно е тяхното теоретическо усвояване и практическо използване от обществото като цяло, тъй като Република България като членна ЕС трябва да предоставя сигурност и защита на класифицирана и неклассифицирана информация и отговаря на нарастващите изисквания за обмяна на документи по електронен път, за сметка на хартиените.

Въпреки, че се предоставя много високо ниво на сигурност в изграждащата ги технология, те са примамлива цел за атаки от хакери. Електронните подписи не предлагат 100% сигурност, но ще се използват още дълго време. Ще си позволя да цитирам *Bruce Schneier*: “*All that the safe buys you is a hour. Nothing is perfect.*”

Използвана литература

- 1) “Хакове за мрежова сигурност” – Андрю Локхарт, O’Reilly, София 2005
 - 2) “Основи на мрежовата сигурност” – Швета Базин, Duo Design, 2004
 - 3) Лекции доц. д-р Стефка Буюклиева
 - 4) <http://www.gat3way.eu/index.php?mact=News,cntnt01,detail,0&cntnt01articleid=90&cntnt01returnid=15>
 - 5) <http://newhorizons.bg/blog/2011/04/horizons-obyavi-dati-za-parvite-kursove-za-eti/>
 - 6) http://www.di-mgt.com.au/rsa_alg.html#keygen
- и др.